FECAP - FUNDAÇÃO ESCOLA DE COMÉRCIO ÁLVARES PENTEADO

Curso de Ciência da Computação
6º Semestre - Turma 6º CCOMP

SMASH

RELATÓRIO DE STATUS E MITIGAÇÃO DE RISCOS

Entrega 2 - Redes de Computadores e Cibersegurança

Projeto 7 - Grupo Smash

Felipe Vallim Soares - 24026060
Guilhermy Mariano Lisboa Garcia - 23025371
Gustavo Oliveira Demetrio - 24026213
Saulo Pereira de Jesus - 24026095

Prof. Victor Bruno Alexander Rosetti

São Paulo
2026

IDENTIFICAÇÃO DO DOCUMENTO

Quadro 1 - Identificação do relatório.

Campo	Informação
Projeto	Smash - parede instrumentada de treino de tênis (Projeto 7)
Disciplina	Redes de Computadores e Cibersegurança - Entrega 2
Data	06/11/2026
Documento anterior	Plano de Gerenciamento de Riscos (Entrega 1, 25/09/2026)
Repositório	*https://github.com/2026-2-NCC6/Projeto7*
Código de referência	Commit *a4cfb7e0c574d13b2bb1074622e7878a5f094830*, pasta *src/Entrega1*

1 INTRODUÇÃO

Este relatório complementa o Plano de Gerenciamento de Riscos da Entrega 1. Naquele plano, a equipe encontrou 19 riscos no Smash e definiu como tratar cada um, e a maioria ficou marcada para ser corrigida até a Entrega 2. Aqui mostramos o que foi corrigido no código, como cada correção foi testada e o que ainda falta. A numeração é a mesma da Entrega 1 (R01 a R19), e os riscos novos começam em R20.

Desde a Entrega 1, três mudanças no projeto afetam os riscos: a parede passou de nove alvos (3 × 3) para seis (3 × 2), com cada sensor ligado direto a um pino do ESP32, sem multiplexador; a integração MQTT saiu do projeto, porque o enunciado a cita só como uma das opções de comunicação; e a parede ganhou um atuador, o LED da própria placa.

1.1 Como as correções foram verificadas

Cada correção foi conferida com um teste que pode ser repetido, como o Plano da Entrega 1 exigia:

- **Testes automáticos:** 83 no backend e 117 no aplicativo, todos passando.
- **Ataques simulados na API:** requisições feitas como faria um aplicativo modificado, como senha errada repetida e resultado de partida inventado.
- **Ataques simulados na parede:** conexões ao emulador da parede, que segue as mesmas regras do firmware, sem senha, com senha errada e com excesso de comandos.
- **Verificação de bibliotecas:** o npm audit, que lista falhas conhecidas nas bibliotecas usadas, rodado antes e depois das correções.

2 RESUMO DO STATUS DOS RISCOS

Nenhum risco Extremo continua aberto. Dos 13 riscos Extremos e Altos da Entrega 1, 12 foram corrigidos no código, e o R13 deixou de existir com a saída do MQTT do projeto.

Quadro 2 - Situação dos 19 riscos da Entrega 1.

Status	Riscos	Total
Corrigido no código	R02, R03, R04, R05, R06, R07, R08, R09, R10, R11, R12 e R17	12
Parcial: falta publicar a API	R01	1
Encerrado	R13 (risco eliminado) e R19 (resolvido desde a Entrega 1)	2
Em andamento, fora do código	R14, R15, R16 e R18	4

O Quadro 3 usa a mesma matriz de probabilidade e impacto da Entrega 1 para mostrar a severidade que sobra depois das correções, já com os três riscos novos (seção 5). Para os riscos da parede, ela considera a placa gravada com o firmware novo.

Quadro 3 - Matriz de probabilidade e impacto com a severidade que sobrou.

Probabilidade \ Impacto	Muito Baixo	Baixo	Médio	Alto	Muito Alto
Muito Alta	Médio	Alto	Alto	Extremo	Extremo
Alta	Baixo	Médio	Alto	Alto	Extremo
Média	Baixo	**Médio** R21	**Médio** R04, R16, R22	**Alto** R14	**Alto** R01
Baixa	Muito Baixo	**Baixo** R12	**Baixo** R05, R06, R10, R11, R20	**Médio** R02, R07, R15, R17, R18	**Médio** R09
Muito Baixa	Muito Baixo	Muito Baixo	**Baixo** R08, R19	**Baixo** R03	Médio

- **Extremo:** nenhum (eram 3 na Entrega 1).
- **Alto:** 2 (eram 10): o R01, até a API ser publicada com HTTPS, e o R14, que é físico e não se resolve no código.
- **Médio:** 10. **Baixo:** 9.

3 VULNERABILIDADES CORRIGIDAS NO CÓDIGO

Para cada risco tratado, mostramos o problema e a correção. No título, entre parênteses, está a severidade na Entrega 1 e a que sobrou depois da correção. Os testes estão na seção 4, e o commit de cada correção está no Anexo A.

R01 - Comunicação com a API sem criptografia (Extremo → Alto)

- **Problema:** o aplicativo enviava e-mail, senha e o token de acesso sem criptografia, e qualquer pessoa na mesma rede podia ler.
- **Correção:** a API passou a aceitar conexões criptografadas (HTTPS) e, quando recebe um certificado, recusa as que não são. A versão final do aplicativo não aceita um endereço da API sem HTTPS.
- **O que falta:** publicar a API em um servidor com certificado reconhecido. Até lá, o risco continua Alto.

R02 - Qualquer aparelho podia se conectar à parede (Extremo → Médio)

- **Problema:** qualquer aparelho no Wi-Fi da parede podia receber os impactos e mandar comandos.
- **Correção:** a parede agora exige uma senha de pareamento, que só o aplicativo da equipe conhece. Sem ela, a conexão é recusada e fechada, e os impactos vão só para o aplicativo pareado.
- **O que falta:** a conexão com a parede continua sem criptografia, porque o ESP32 não tem folga para isso. Quem protege a senha de pareamento é o Wi-Fi da parede, que tem senha forte (R03).

R03 - Senha do Wi-Fi da parede fraca e publicada (Extremo → Baixo)

- **Problema:** a senha da rede da parede era "smash1234" e estava num arquivo do repositório público.
- **Correção:** as senhas saíram do repositório e ficam num arquivo local (*secrets.h*) que o Git ignora. Sem ele, o firmware nem compila. O guia do firmware ensina a gerar uma senha forte para cada parede.
- **O que falta:** a senha antiga continua no histórico do Git, então é tratada como vazada e não pode mais ser usada. A placa precisa ser gravada com uma senha nova.

R04 - Resultado da partida aceito sem prova (Alto → Médio)

- **Problema:** o aplicativo informava o resultado pronto, e o servidor aceitava. Um aplicativo modificado podia inventar partidas e subir no ranking.
- **Correção:** agora o servidor abre a partida antes do jogo e entrega um comprovante assinado com o jogador, o modo, o nível e a hora de início. Ele

aceita um único resultado por comprovante, recusa níveis ainda bloqueados e recusa resultados impossíveis: duração maior que o tempo real, mais batidas do que a parede consegue registrar (uma a cada 200 ms) ou pontuação acima do máximo.

- **O que falta:** dentro desses limites, ainda é possível declarar um resultado possível que não aconteceu. Resolver isso exigiria que a própria parede assinasse os impactos.

R05 - Qualquer conexão trocava a sessão da parede (Alto → Baixo)

- **Problema:** qualquer aparelho conectado podia trocar o identificador de sessão que a parede grava em cada impacto.
- **Correção:** a parede atende um aplicativo por vez. O primeiro que pareia fica com ela até sair; um segundo recebe "parede ocupada" e é desconectado.

R06 - Login sem limite de tentativas (Alto → Baixo)

- **Problema:** dava para tentar senhas sem limite no login e criar contas sem limite.
- **Correção:** depois de 5 tentativas na mesma conta em 15 minutos, ou de 10 tentativas do mesmo endereço em 1 minuto, o login fica bloqueado por alguns minutos, com a mensagem "Muitas tentativas".

R07 - Parede sem limite de mensagens e comandos (Alto → Médio)

- **Problema:** a parede aceitava mensagens de qualquer tamanho e comandos sem limite, e um aplicativo que sumia sem desconectar continuava ocupando a parede.
- **Correção:** mensagens com mais de 256 bytes e comandos acima de 20 por segundo são recusados, e a parede desconecta o aplicativo que para de responder.
- **O que falta:** um ataque que congestione o próprio sinal de Wi-Fi não se resolve por software e fica aceito.

R08 - API aberta a qualquer site e rede (Médio → Baixo)

- **Problema:** a API aceitava chamadas vindas de qualquer site e escutava em todas as redes do computador.
- **Correção:** por padrão, a API só aceita conexões do próprio computador e nenhum site de fora. Liberar a rede de testes ou um site passou a ser uma escolha explícita na configuração.

R09 - Senha padrão do banco de dados (Alto → Médio)

- **Problema:** sem configuração, a API tentava entrar no banco com um usuário e uma senha conhecidos.

- **Correção:** a API não tem mais senha padrão: sem as credenciais configuradas, ela não inicia.
- **O que falta:** no servidor final, usar uma conta do banco só com as permissões que a aplicação precisa.

R10 - Sair da conta não cancelava o acesso (Médio → Baixo)

- **Problema:** o token de acesso valia 7 dias, e sair da conta não o cancelava: uma cópia dele continuava funcionando.
- **Correção:** ao sair da conta, o servidor cancela todos os tokens do jogador, em qualquer aparelho. A validade caiu para 12 horas.

R11 - Bibliotecas com falhas conhecidas (Alto → Baixo)

- **Problema:** o npm audit apontava falhas conhecidas nas bibliotecas, e entre as entregas surgiu uma falha crítica no backend.
- **Correção:** o backend foi atualizado e ficou sem nenhum alerta. No aplicativo restaram 5 alertas, todos numa ferramenta do Expo que roda só no computador da equipe e não vai para o celular.

R12 - Poucos registros de segurança (Médio → Baixo)

- **Problema:** a API quase não registrava eventos de segurança.
- **Correção:** a API registra cada login, cadastro e saída da conta e cada acesso recusado, com horário, endereço e resultado. O e-mail aparece mascarado, e senha e token nunca entram no registro.

R17 - Dados reais em demonstrações (Alto → Médio)

- **Problema:** não havia como criar contas de teste, e nas apresentações alguém acabaria usando o próprio e-mail.
- **Correção:** dois comandos criam contas fictícias, com e-mails que não pertencem a ninguém, e as apagam depois do evento, com todo o histórico delas.
- **O que falta:** usar os comandos antes e depois de cada apresentação.

4 EVIDÊNCIAS DOS TESTES DE SEGURANÇA

O Quadro 4 reúne os ataques simulados contra a API, com o backend e o banco de dados rodando, e contra o emulador da parede. Cada linha mostra o que foi tentado e o que aconteceu.

Quadro 4 - Ataques simulados e resultados.

Risco	O que foi tentado	Resultado
R01	Acessar a API com criptografia (HTTPS, com certificado de teste)	Funcionou
R01	Acessar a mesma porta sem criptografia	Conexão recusada
R02	Conectar à parede sem senha de pareamento	Recusado e desconectado
R02	Conectar à parede com a senha errada	Recusado e desconectado
R03	Compilar o firmware sem o arquivo de senhas	Não compila e explica o que falta
R04	Começar o nível 5 sem ter passado do 4	Recusado: "nível ainda bloqueado"
R04	Enviar o mesmo resultado duas vezes	A segunda vez foi recusada
R04	Enviar um resultado sem comprovante	Recusado
R04	Declarar 1 hora de jogo logo depois de começar	Recusado
R04	Declarar 999.999 pontos com 6 acertos	Recusado
R04	Trocar o nível no resultado enviado	Recusado
R05	Conectar um segundo aplicativo com a senha certa	Recusado: "parede ocupada"
R06	Errar a senha 7 vezes seguidas na mesma conta	Da 6ª tentativa em diante: "Muitas tentativas"
R07	Mandar uma mensagem de 400 bytes à parede	Recusada
R07	Mandar 30 comandos de uma vez à parede	20 aceitos e 10 recusados
R08	Chamar a API a partir de um site qualquer	Sem permissão
R10	Usar o token depois de sair da conta	Acesso negado
R12	Errar o login e conferir o registro	Registrado, com e-mail mascarado e sem a senha

Quadro 5 - Falhas conhecidas nas bibliotecas (npm audit).

Parte	Entrega 1 (12/09)	Antes das correções (25/10)	Depois das correções
Backend	9 alertas	11, sendo 1 crítico	Nenhum
Aplicativo	18 alertas	16, sendo 1 crítico	5, só em ferramenta do computador da equipe

5 NOVOS RISCOS E PRÓXIMOS PASSOS

5.1 Riscos que se concretizaram

- **R03:** a senha antiga da parede foi publicada antes da correção e é tratada como vazada.
- **R11:** surgiram falhas novas nas bibliotecas entre as entregas, inclusive uma crítica, o que mostra que a verificação precisa ser repetida a cada entrega.

5.2 Riscos novos

Quadro 6 - Riscos identificados na Entrega 2.

ID	Risco	Severidade	Resposta
R20	A senha de pareamento fica dentro do aplicativo e pode ser extraída do arquivo do app.	Baixo	Aceitar: senha diferente por parede, trocada antes de cada apresentação.
R21	Versões antigas do aplicativo não salvam partidas, porque o servidor exige o comprovante (R04).	Médio	Mitigar: usar só a versão atual nas apresentações.
R22	Atrás de um servidor intermediário (proxy), o limite de login trataria todos os aparelhos como um só.	Médio	Prevenir: opção que usa o endereço real de cada aparelho. Já implementada.

5.3 O que falta antes da apresentação

- **Servidor:** publicar a API com HTTPS (R01) e criar uma conta do banco só com as permissões necessárias (R09).
- **Parede:** gravar o firmware novo com senhas novas, repetir na placa os testes do Quadro 4 (R02, R03, R05 e R07) e continuar a validação física com os seis alvos (R14).
- **Apresentação:** usar contas fictícias e apagá-las depois (R17) e repetir o npm audit antes (R11).

APROVAÇÃO

Quadro 7 - Aprovação do relatório.

Nome	Cargo	Assinatura	Data
Saulo Pereira de Jesus	Gerente do Projeto	Saulo Pereira de Jesus	06/11/2026
Felipe Vallim Soares	Responsável - Firmware (ESP32)	Felipe Vallim Soares	06/11/2026
Guilhermy Mariano Lisboa Garcia	Responsável - Backend (API e banco)	Guilhermy Mariano Lisboa Garcia	06/11/2026
Gustavo Oliveira Demetrio	Responsável - Aplicativo Mobile	Gustavo Oliveira Demetrio	06/11/2026
Prof. Victor Bruno Alexander Rosetti	Patrocinador do Projeto		

ANEXO A - REGISTRO DE RISCOS ATUALIZADO

O Quadro 8 traz os 19 riscos da Entrega 1 e os três novos, com a severidade antes e depois e o commit de cada correção. No repositório, cada commit mostra exatamente quais arquivos foram alterados.

Quadro 8 - Registro de riscos atualizado.

ID	Risco	Antes	Status	Depois	Commit
R01	Comunicação com a API sem criptografia	Extremo	Parcial	Alto	810a16b e c98a80b
R02	Parede aceitava qualquer conexão	Extremo	Corrigido	Médio	3946d66
R03	Senha do Wi-Fi da parede fraca e publicada	Extremo	Corrigido	Baixo	3946d66
R04	Resultado da partida aceito sem prova	Alto	Corrigido	Médio	3b5380b
R05	Qualquer conexão trocava a sessão da parede	Alto	Corrigido	Baixo	3946d66
R06	Login sem limite de tentativas	Alto	Corrigido	Baixo	9a8417b
R07	Parede sem limite de mensagens e comandos	Alto	Corrigido	Médio	3946d66
R08	API aberta a qualquer site e rede	Médio	Corrigido	Baixo	810a16b
R09	Senha padrão do banco de dados	Alto	Corrigido	Médio	da16065
R10	Sair da conta não cancelava o acesso	Médio	Corrigido	Baixo	e8a8476
R11	Bibliotecas com falhas conhecidas	Alto	Corrigido	Baixo	b59160e e 3ce31d4
R12	Poucos registros de segurança	Médio	Corrigido	Baixo	9b5698f
R13	MQTT sem controles de segurança	Alto	Encerrado	-	cb9f2ac
R14	Vibração entre as placas troca o alvo	Alto	Em andamento	Alto	-
R15	Pouco tempo para as correções	Alto	Em andamento	Médio	-
R16	Mudança de critérios ou datas das entregas	Médio	Em andamento	Médio	-
R17	Dados reais em demonstrações	Alto	Corrigido	Médio	a4cfb7e
R18	Falha da única placa ESP32	Médio	Em andamento	Médio	-
R19	Wi-Fi do local indisponível	Médio	Encerrado	Baixo	-
R20	Senha de pareamento dentro do aplicativo	-	Aceito	Baixo	-
R21	Versões antigas do app não salvam partidas	-	Corrigido	Médio	3b5380b
R22	Limite de login atrás de um proxy	-	Corrigido	Médio	9a8417b